

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on June 7, 2022. The complaint is directed against WILLOUGHBY COLLEGE, S.A. with NIF A28407518 (hereinafter, WILLOUGHBY COLLEGE). The reasons on which the complaint is based are as follows:

Complaint related to the sending of emails to a plurality of recipients without using the BCC functionality, which implies the disclosure of the recipients' addresses. The sender is the school where the complainant's child studies, as stated by the complainant, who provides copies of three messages dated 11/6/2020, 12/22/2021, and 5/17/2022 respectively.

The complainant states that, previously, at least on two occasions (November 2020 and December 2021), he had already warned the person responsible that he should not send messages revealing third-party data again (the disclosure is limited to the email address, as the content of the submitted messages consists of announcements of events to be held at the school).

Date on which the reported events took place: 11/6/2020, 12/22/2021, and 5/17/2022.

Along with the notification, the following is attached:

- Email dated 11/6/2020 sent from the address ***EMAIL.1, addressed to 48 recipients, including the complainant's email address, with the subject "School Farm Visit." The email addresses of the recipients are visible. It also includes the complainant's response to this email on the same date, requesting explanations for why his email address was provided to the other recipients.
- Email dated 12/22/2021 sent from the address ***EMAIL.2, addressed to 31 recipients, including the complainant's email address, with the subject "Merry Christmas!" The email addresses of the recipients are visible. It also includes the complainant's response to this email on the same date expressing his disagreement with his email address being shared with the other recipients and requesting that it not happen again.
- Email dated 5/17/2022 sent from the address ***EMAIL.2, addressed to more than 100 recipients, including the complainant's email address, with the subject "Summer Show." The email addresses of the recipients are visible.

SECOND: The Spanish Agency for Data Protection forwarded the complaint to WILLOUGHBY COLLEGE for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 07/14/2022 as evidenced by the acknowledgment of receipt in the file.

THIRD: On September 7, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

RESULT OF THE INVESTIGATIVE ACTIONS

It has been verified by the data inspection that, as stated in the "Legal Notice" of the website wic.edu.es, this domain is owned by the entity WILLOUGHBY COLLEGE, S.A.

The data inspection has requested WILLOUGHBY COLLEGE, through electronic notifications sent on 09/21/2022 and reiterated on 12/19/2022, the following information and documentation:

"1.- Detailed and chronological description of the events that occurred.

2.- Detailed specification of the causes that made the breach possible, including information regarding

the conditions that led to the occurrence of the reported events.

3.- Possible consequences for the affected individuals.

4.- Information regarding whether you are aware of the use by third parties of the personal data obtained through the breach, in which case, documentation held by your entity regarding this.

5.- Information regarding the communication made to the affected individuals. Provide a copy of the notification sent and the procedure for sending it, if applicable.

6.- Regarding the security of personal data processing:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/16

6.1. A copy of the Risk Analyses (AR) carried out, if applicable, regarding the processing activity that suffered the security breach prior to the incident that occurred.

6.2. Detailed and documented evidence of the security measures implemented prior to the incident in relation to the security breach.

6.3. Information regarding the reason why the implemented security measures did not prevent the security incident.

6.4. Detailed and documented evidence of the technical and organizational measures adopted or modified to avoid, as much as possible, security incidents like the one that occurred.

7.- The reason why the breach was not reported to the Spanish Agency for Data Protection within 72 hours from when it occurred.

8.- Information on the recurrence of these events and the number of analogous events that have occurred over time.

9.- Any other information deemed relevant.

The request for information and its reiteration were withdrawn by the recipient on the same day they were made available to them through the Single Electronic Enabled Direction service, on 21/9/2022 and 19/12/2022 respectively.

CONCLUSIONS

- The claimant provides copies of 3 emails dated 6/11/2020, 22/12/2021, and 17/5/2022 respectively, which they state they received in their email inbox. These emails were sent from the domain wic.edu.es and were sent to multiple recipients with the email addresses visible to all of them, including that of the claimant (***EMAIL.3).

- The domain wic.edu.es is owned by WILLOUGHBY COLLEGE, S.A.

- In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights, the complaint was forwarded to the respondent for analysis and response within one month. The notification was received by the recipient on 8/7/2022 without a response being obtained, so the complaint was admitted for processing.

- The data inspection has requested information and documentation from the respondent on two occasions regarding the claimed facts through electronic notification, which has been withdrawn by the recipient, with no response obtained.

- The security measures implemented by the respondent, responsible for the processing, prior to the claimed facts and the measures adopted subsequently are unknown.

FIFTH: According to the report obtained from the AXESOR tool, the entity WILLOUGHBY COLLEGE, S.A. is a small company established in 1975, with a turnover of XXXXXXXX euros in 2021.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/16

SIXTH: On June 27, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against WILLOUGHBY COLLEGE, in accordance with the provisions of

Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, and for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, in which it was indicated that they had a period of ten days to submit allegations.

This initiation agreement, which was notified to WILLOUGHBY COLLEGE in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on July 5, 2023, as evidenced by the acknowledgment of receipt in the file.

SEVENTH: On July 7, 2023, a written response was received at this Agency, in due time and form, from WILLOUGHBY COLLEGE in which they presented allegations to the initiation agreement, in which, in summary, they stated that they had made the voluntary payment of the sanction of EXP. 202302302, and that this Agency had issued a resolution terminating the procedure due to voluntary payment.

EIGHTH: On September 6, 2023, the instructing body of the sanctioning procedure formulated a proposal for resolution, in which it proposes that the Director of the AEPD sanction WILLOUGHBY COLLEGE, with NIF A28407518, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, with a fine of €5,500 (five thousand five hundred euros), and for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, with a fine of €500 (five hundred euros).

This proposal for resolution, which was notified to WILLOUGHBY COLLEGE in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on September 15, 2023, as evidenced by the acknowledgment of receipt in the file.

NINTH: On September 27, 2023, a written response was received at this Agency, in due time and form, from WILLOUGHBY COLLEGE in which they presented allegations to the proposal for resolution, in which, in summary, they stated the existence of a technical impossibility to provide documentation in response to the information requests made by this Agency in the previous investigation proceedings, alleging the voluntary payment of the sanction and, finally, providing a document enumerating the actions taken after receiving the complaint and request for information.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/16

From the actions taken in the present procedure and the documentation on file, the following has been established:

PROVEN FACTS

FIRST: On November 6, 2020, an email was sent from the address ***EMAIL.1 to 48 recipients, including the email address of the claimant, ***EMAIL.3, with the subject "School Farm Visit." The email addresses of the recipients are visible.

On the same day, in response to the email referred to in the previous paragraph, the claimant, from the address ***EMAIL.3, sent an email to ***EMAIL.1, with a copy to ***EMAIL.4, with the following message:

"Dear Sirs,

I request that you explain why you have made my email address public and provided it to a group of people. It is a confidential personal data, and now it is in the hands of other people who have already written to me.

Not only have you had my (...) with the surnames inverted for years without verifying what the Civil Registry said, but now we have a new violation of data protection regulations.

Sincerely,

A.A.A."

SECOND: On December 22, 2021, an email was sent from the address ***EMAIL.2 to 31 recipients, including the email address of the claimant, with the subject "Merry Christmas!" The email addresses

of the recipients are visible.

On December 23, 2021, in response to the email referred to in the previous paragraph, the claimant, from the address ***EMAIL.3, sent an email to ***EMAIL.2, with a copy to ***EMAIL.4, with the following message:

"Dear XXXXX,

Thank you very much for your email.

However, as I have indicated to the school on previous occasions, you cannot send emails without using BCC, as you are once again sharing the personal addresses of the parents without their consent. You certainly do not have mine. I hope this situation does not occur again, although given the recurrence of the behavior, I fear we will continue like this indefinitely.

Best regards."

THIRD: On May 17, 2022, an email was sent from the address ***EMAIL.2 to more than 100 recipients, including the email address of the claimant, ***EMAIL.3, with the subject "Summer Show."

The email addresses of the recipients are visible.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/16

LEGAL GROUNDS

I

Competence and applicable regulations

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, by the general rules on administrative procedures."

II

Preliminary issues

In this case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, as WILLOUGHBY COLLEGE collects, stores, and communicates, among others, the following personal data of individuals: surnames and email addresses, among other processing activities.

WILLOUGHBY COLLEGE carries out this activity in its capacity as data controller, as it determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in section 1.f) of Article 5 of the GDPR. In turn, the security of the processing of personal data is regulated in Articles 32 of the GDPR.

III

Response to the allegations made against the initiation agreement and the allegations made against the proposed resolution

A) Regarding the allegations made against the initiation agreement of this sanctioning procedure, a response is provided according to the order presented by WILLOUGHBY COLLEGE:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/16

1.- Having made the payment of the sanction.

Regarding this allegation, it should be noted that the payment made by WILLOUGHBY COLLEGE on March 24, 2023, corresponds to the sanction imposed in the EXP202302302 (PS/00083/2023), due to the commission of the infringement provided for in Article 83.5.e) of the GDPR, "failure to provide access in violation of Article 58, paragraph 1."

Article 58.1 of the GDPR grants each supervisory authority the following investigative powers: "a) to order the controller and the processor and, where applicable, the representative of the controller or the processor, to provide any information required for the performance of their tasks; b) to carry out investigations in the form of data protection audits; c) to carry out a review of the certifications issued pursuant to Article 42, paragraph 7; d) to notify the controller or the processor of any alleged infringements of this Regulation; e) to obtain from the controller and the processor access to all personal data and all information necessary for the performance of their tasks; f) to obtain access to all premises of the controller and the processor, including any equipment and means of processing data, in accordance with the procedural law of the Union or of the Member States."

According to the resolution of PS/00083/2023, WILLOUGHBY COLLEGE did not respond to the two requests for information made by this Agency: "...In the context of the investigation proceedings, two requests for information were sent to the respondent party regarding the complaint mentioned in the first section, requiring them to submit the information and documentation specified therein to this Agency within ten working days and five working days, respectively. The first of these was registered out on September 21, 2022, while the second was registered on December 9, 2022.

THIRD: The requests for information, which were notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), were received by the respondent party on September 30, 2022, and December 9, 2022, as evidenced by the Notific@ certificates in the file.

FOURTH: Regarding the requested information, the respondent party has not sent any response to this Spanish Agency for Data Protection."

In PS/00083/2023, an initial administrative fine of €1,500 was set, an amount that, applying the reduction for voluntary payment of the sanction, accumulable to the one corresponding to the acknowledgment of responsibility, was reduced to an amount of €900. This amount was paid by WILLOUGHBY COLLEGE, as justified in its allegations.

Regardless of the initiation of the procedure PS/00083/2023, this Agency has deemed it appropriate to initiate sanctioning proceedings due to the facts recorded in the complaint filed by the complainant party, in which WILLOUGHBY COLLEGE is the alleged responsible party for the commission of two.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/16

violations, one of Article 5.1.f) of the GDPR, and another of Article 32 of the GDPR, therefore, on June 27, 2023, the Director of this Agency issued a resolution to initiate sanctioning proceedings, PS/00057/2023.

Consequently, the payment of the sanction referred to by WILLOUGHBY COLLEGE in its allegation, as a cause for termination of the sanctioning procedure provided for in Article 85 of the LPACAP due to voluntary payment by the alleged responsible party, is applicable to PS/00083/2023, not to the present sanctioning procedure (PS/00057/2023).

For all the above, the present allegation is dismissed.

B) Regarding the allegations made concerning the proposed resolution of the present sanctioning procedure, a response is provided according to the order presented by WILLOUGHBY COLLEGE:

- Technical impossibility of providing documentation in response to the information requests made by this Agency in the prior investigation proceedings

According to WILLOUGHBY COLLEGE, its staff attempted several times to send the documentation in response to the information request made by this Agency, but due to a problem with the electronic signature, they were unable to submit said documentation through the electronic registry, and

ultimately decided to send it via email, despite being informed by this Agency that it was not a valid means of submitting the documentation. Finally, WILLOUGHBY COLLEGE states: "Upon reaching this situation and not knowing how to act, we let it pass until we received the initiation of the sanctioning procedure on March 16, 2023, with file number: EXP202302302."

With this argument, WILLOUGHBY COLLEGE does not refute the facts subject to the complaint that led to the initiation of the present procedure, but rather refers to factual issues that occurred in actions carried out by this Agency prior, specifically, to the impossibility of submitting documentation through the electronic registry to respond to the information requests made by this Agency.

As was informed to WILLOUGHBY COLLEGE in the information requests made by this Agency, the failure to comply with the legal obligation to respond to said requests could result in the commission of an infringement classified in Article 72.1.ñ) of the LOPDGGD, punishable according to Article 58.2 of the GDPR, therefore, due to the lack of response from WILLOUGHBY COLLEGE to the information request of September 21, 2022, as well as the reiteration of said request, dated December 9, 2022, a resolution to initiate sanctioning proceedings (PS/00083/2023) was issued, which concluded with a resolution terminating the procedure due to voluntary payment of the sanction and acknowledgment of responsibility for the facts by WILLOUGHBY COLLEGE.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/16

For all the reasons stated above, the present allegation is dismissed.

- The resolution proposal is based on the fact that, according to the resolution of PS/00083/2023, WILLOUGHBY COLLEGE had not responded to the information requests made in September and December of 2022, having acknowledged its error and proceeding to voluntarily pay the fine.

As already argued in the response to the allegations presented by WILLOUGHBY COLLEGE to the Initiation Agreement, the facts that led to the initiation of procedure PS/00083/2023 were the lack of attention to two information requests made by this Agency ("The first was registered for dispatch on September 21, 2022, while the second was registered on December 9, 2022"). However, the sanctioning procedure PS/00057/2023 aims to determine the administrative responsibility for the facts recorded in the complaint filed by the claimant, in which WILLOUGHBY COLLEGE is the alleged responsible party for committing two infractions: one under article 5.1.f) of the GDPR, for violating the confidentiality of the personal data of the parents of the students in the processing carried out by WILLOUGHBY COLLEGE by sending emails to multiple recipients without using the blind carbon copy functionality, and another under article 32 of the GDPR, for the absence of appropriate technical and organizational measures to ensure the confidentiality of the data.

Consequently, the acknowledgment of responsibility and voluntary payment of the fine made by WILLOUGHBY COLLEGE on March 22, 2023, does not refer to this procedure (PS/00057/2023), whose initiation agreement date (June 27, 2023) is subsequent to that payment, but rather to PS/00083/2023.

For all the reasons stated above, the present allegation is dismissed.

- The content of the emails did not contain information of "extraordinary severity."

In response to this argument, it should be emphasized that the principle of confidentiality aims to prevent leaks of personal data, in this case, the email, name, and surnames of the parents of the students who were recipients of the messages sent by WILLOUGHBY COLLEGE, which was caused by not using the "BCC" ("blind carbon copy") functionality when sending the messages. Therefore, the content of the emails does not determine the existence or non-existence of responsibility regarding the facts constituting the infractions attributed to WILLOUGHBY COLLEGE.

For all the reasons stated above, the present allegation is dismissed.

- Actions taken after receiving the complaint and request for information

WILLOUGHBY COLLEGE claims that, since June 2022, it has adopted measures to prevent leaks of personal data such as the one that occurred in this case.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/16

In response to this allegation, it should be noted that such measures, detailed in the document dated July 18, 2022, attached to the allegations, were not implemented until this Agency forwarded the complaint to WILLOUGHBY COLLEGE, so they are not spontaneous, nor do they respond to the communication made by the claimant prior to the filing of the complaint.

For all the reasons stated above, the present allegation is dismissed.

IV

Principle of integrity and confidentiality

Article 5.1.f), "Principles relating to processing," of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, the documentation in the file provides clear indications that WILLOUGHBY COLLEGE violated article 5.1.f) of the GDPR when, on three occasions (11/6/2020, 12/22/2021, and 5/17/2022), emails were sent from an email address with the domain "wic.edu.es," owned by WILLOUGHBY COLLEGE, to multiple recipients without using the blind carbon copy option, violating the confidentiality in the processing of personal data. The principle of confidentiality aims to prevent unauthorized leaks of personal data by the data subjects.

Therefore, in accordance with the evidence available at this time in the resolution of the sanctioning procedure, it is considered that the known facts constitute an infraction attributable to WILLOUGHBY COLLEGE for violating article 5.1.f) of the GDPR.

V

Classification and qualification of the infraction of article 5.1.f) of the GDPR

The aforementioned infraction of article 5.1.f) of the GDPR constitutes the commission of the infractions classified in article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Infractions of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/16

In the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9; (...)"

For the purposes of the statute of limitations, Article 72 "Very Serious Offenses" of the LOPDGDD indicates:

"1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious offenses and shall be subject to a three-year statute of limitations for substantial violations of the articles mentioned therein, particularly the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Sanction for the violation of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As an aggravating circumstance of liability:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm suffered (paragraph a): The complainant warned WILLOUGHBY COLLEGE at least on two occasions, via emails dated 06/11/2020 and 23/12/2021 on file, of the breach of confidentiality by sending emails to multiple recipients without using the "BCC" function.

The balance of the circumstances contemplated in Article 83.2 of the GDPR, with respect to the infringement committed by violating what is established in Article 5.1.f) of the GDPR, allows for the imposition of a sanction of €5,500 (five thousand five hundred euros).

VII

Security Measures

Article 32 "Security of Processing" of the GDPR establishes:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/16

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law."

In this case, the documentation in the file provides clear evidence that WILLOUGHBY COLLEGE has violated Article 32 of the GDPR, by not having adequate organizational or security measures either initially or as a consequence of the warnings sent by the complainant alerting them to what was occurring.

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of probability and severity for the

rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures must be made taking into account: pseudonymization and encryption, the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/16

capacity to ensure confidentiality, integrity, availability, and resilience, the capacity to restore availability and access to data after an incident, verification process (which is not an audit), assessment, and evaluation of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention will be paid to the risks presented by the processing of data, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same regard, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the risks inherent in the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the costs of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial harm.”

The responsibility of WILLOUGHBY COLLEGE is determined by the lack of security measures evidenced in the complaint and the documentation provided, as it is responsible for making decisions aimed at effectively implementing appropriate technical and organizational measures to ensure an adequate level of security relative to the risk to ensure the confidentiality of the data, restoring its availability, and preventing access to it in the event of a physical or technical incident. However, from the documentation provided along with the complaint, it is clear that the entity has not only failed to comply with this obligation but has also not adopted measures in this regard, despite having been informed of the complaint filed.

Therefore, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to WILLOUGHBY COLLEGE for violation of Article 32 of the GDPR.

VIII

Classification and qualification of the infringement of Article 32 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/16

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

For the purposes of the limitation period, Article 73 “Serious infringements” of the LOPDGDD indicates: “According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

IX

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of a sanction of €500 (five hundred euros).

X

Imposition of measures for the infringement of Article 32 of the GDPR

It is agreed to impose on the controller the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, when appropriate, in a specified manner and within a specified period...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/16

It is warned that failure to comply with the possible order for the adoption of measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on WILLOUGHBY COLLEGE, S.A., with NIF A28407518:

- For an infringement of article 5.1.f) of the GDPR, classified in article 83.5 of the GDPR, a fine of €5,500 (five thousand five hundred euros).

- For an infringement of article 32 of the GDPR, classified in article 83.4 of the GDPR, a fine of €500 (five hundred euros).

SECOND: TO NOTIFY this resolution to WILLOUGHBY COLLEGE, S.A.

THIRD: TO ORDER WILLOUGHBY COLLEGE, S.A., with NIF A28407518, that pursuant to article 58.2.d) of the GDPR, within a period of 2 months, to prove that it has adopted appropriate technical and organizational measures to prevent breaches of the confidentiality of personal data in the sending of emails addressed to multiple recipients.

FOURTH: To warn the sanctioned party that it must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that

appears in the heading of this document, into the restricted account No. ES00 0000 0000 0000 0000 0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/16

Against this resolution, which concludes the administrative route in accordance with article 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of article 90.3 a) of the LPACAP, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-120722

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es